

RHOCP CVE 대응

Red Hat

InSoo Hwang

Associate Principal Solution Architect

26.09.09

Red Hat RHOCPP CVE 대응

Red Hat의 근본적인 CVE 대응 원칙

Red Hat은 단순히 최신 업스트림 버전을 배포하는 것이 아니라, 안정성과 보안을 동시에 확보하는 방식을 취합니다.



Backporting

백포팅 기술 적용

새로운 업스트림 버전으로 성급하게 업데이트하여 새로운 버그를 도입하는 대신, 현재 안정화된 버전에 보안 패치만을 추출하여 적용합니다. 이를 통해 고객 애플리케이션의 호환성(API/ABI)을 유지하면서 보안을 안심하고 강화합니다.



Risk-based Priority

위험 기반 우선순위 지정

모든 CVE를 보안 전문가가 직접 평가하여 영향력을 판단합니다. '중요(Important)' 및 '긴급(Critical)' 이슈에 우선적으로 대응하며, OpenShift의 기본 보안 설정(SELinux, SCC 등) 덕분에 실제 위험도가 낮아지기도 합니다.



Secure Supply Chain

보안 공급망 구축

"정수장(Water Treatment)" 모델을 사용하여 안전한 업스트림 코드를 완벽하게 테스트, 패키징, 암호화 서명 및 검증 과정을 거쳐 최종적으로 신뢰할 수 있는 형태로 사용자에게 안전하게 배포합니다.

OpenShift CVE 이미지 대응 프로세스 (고객 관점)

고객은 다음의 4단계 프로세스를 통해 CVE에 안전하고 체계적으로 대응할 수 있습니다.



① 식별 Identify

Red Hat Insights: 클러스터를 상시 스캔하여 영향 호스트/이미지 식별

Quay Scanner: 레지스트리 저장 이미지 취약점 자동 스캔 및 보고



② 분류 및 분석 Triage

CVE Database: Portal을 통해 실제 OpenShift 환경 영향력 검증

CSAF/VEX 메타데이터: RHCOS 전용 보안 데이터로 정밀한 분석 지원



③ 완화 Mitigate

선제적 위험 차단: 패치 출시 전이라도 SELinux 및 SCC 설정을 통해 공격의 파급력 차단

Non-root 실행: 기본 컨테이너 권한 상승 공격을 원천 무력화



④ 해결 및 배포 Remediate

플랫폼 (RHCOS): OSUS로 클러스터 전체 노드 OS 자동 업데이트

오퍼레이터: OLM을 통한 최신 보안 완료 버전으로 자동 업그레이드

앱 이미지: UBI 기반 재빌드 및 카탈로그의 Hardened Images 활용 지원

주요 도구 및 문서

안전하고 효율적인 인프라 관리를 위한 주요 도구 및 기술 상세 정보입니다.



Red Hat Insights

지능형 분석 및 진단

클러스터와 인프라의 위협을 상시 파악할 수 있는 종합적인 가시성을 제공합니다. 정밀 진단을 통해 문제를 사전에 해결할 수 있습니다.



Red Hat Satellite

폐쇄망 환경 라이프사이클 관리

외부망과 연결되지 않은 폐쇄망 (Air-gapped) 환경 내에서도 보안 패치를 안전하게 스테이징하고 종합적으로 관리할 수 있습니다.



Ansible Automation Platform (AAP)

대규모 자동화 적용

식별된 취약점을 기반으로 실시간 플레이북을 생성하며, 대규모 프로덕션 환경 내 신속하고 정확한 보안 패치 자동 배포를 실현합니다.

Thank you

Red Hat is the world's leading provider of enterprise open source software solutions. Award-winning support, training, and consulting services make Red Hat a trusted adviser to the Fortune 500.



linkedin.com/company/red-hat



youtube.com/user/RedHatVideos



facebook.com/redhatinc



twitter.com/RedHat